

SIMATS ENGINEERING

ASSESSMENT TOOL II – INDUSTRY PROBLEM TASK

Course:	Code:	CO: CO5
Duration:	Total Marks: 100	Reg No / Name:

COURSE OUTCOME COVERED

CO5: *Analyze vulnerabilities in Windows and Linux systems and evaluate security weaknesses in messaging, web, and mobile applications using appropriate exploitation techniques and hacking tools. (BT5)*

Instructions: *Answer all questions. Each question carries 20 marks.*

1. A mid-sized financial organization operates a Windows domain network consisting of 150 interconnected systems. During a security incident investigation, it is observed that attackers have exploited NULL sessions, open RPC services, and misconfigured shared folders to gain unauthorized access. Initial analysis indicates that 45% of systems allow anonymous enumeration, and among those, 60% are susceptible to SMB-based lateral movement attacks. Furthermore, each compromised system can attempt to access 3 additional systems, with a success probability of 0.3 per attempt.

Question:

Analyze the extent of the attack by calculating the number of systems compromised during the initial stage of exploitation. Further, estimate the spread of the attack in the second stage due to lateral movement. Based on your analysis, evaluate whether the network is at risk of a large-scale compromise (greater than 70% of total systems), and justify which vulnerability (NULL sessions, RPC exposure, or weak shares) should be prioritized for immediate mitigation.

2. An enterprise network consists of 120 systems, out of which 70 systems expose RPC services to the internal network. A vulnerability scan reveals that 40% of these systems are susceptible to known exploits, and the probability of successful exploitation for each vulnerable system is 0.5. However, each exploitation attempt carries a detection probability of 0.25 due to intrusion detection systems deployed within the network.

Question:

Determine the expected number of systems that can be successfully compromised by an attacker. Additionally, compute the expected number of detection alerts generated during the exploitation process. Based on your results, critically evaluate whether an attacker aiming to remain stealthy would proceed with exploitation or adopt alternative attack strategies, providing justification for your reasoning.

3. A cloud-hosted Linux server is running multiple services exposed to the internet. Security analysis identifies four critical services, with independent probabilities of vulnerability being 0.3, 0.2, 0.25, and 0.15, respectively. It is also observed that the system has weak file

permissions, which can be exploited with a probability of 0.5 once initial access is gained.

Question:

Evaluate the probability that at least one service is vulnerable and can be exploited by an attacker. Further, compute the overall probability of a full system compromise, considering both service exploitation and privilege escalation through weak permissions. Based on your findings, analyze whether strengthening file permissions alone would significantly reduce the overall risk, and justify your conclusion.

4. An organization uses Network File System (NFS) to share resources across three internal subnets. Due to improper configuration, unauthorized access probabilities from these subnets are estimated as 0.4, 0.3, and 0.2, respectively. Once access to the NFS share is obtained, the probability of privilege escalation to root access is 0.7.

Question:

Calculate the probability that at least one subnet successfully gains unauthorized access to the NFS share. Subsequently, determine the overall probability of a complete system compromise. Based on your analysis, evaluate the effectiveness of restricting NFS access to a single subnet as a mitigation strategy, and justify your recommendation.

5. An e-commerce platform maintains a database containing 50,000 user records, of which 30% are classified as sensitive. A successful SQL injection attack allows data extraction at a rate of 500 records per second. However, the application firewall detects and blocks the attack after 40 seconds.

Question:

Compute the total number of records that can be extracted before the attack is blocked. Determine the percentage of total data compromised, and estimate the number of sensitive records exposed. Based on your analysis, evaluate the severity of the breach and justify whether the existing detection mechanism is sufficient to protect critical data.

Code of Conduct:

I _____ (Name / Reg No) certify that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Criteria	Weightage	Level 4 – Exemplary	Level 3 – Proficient	Level 2 – Developing	Level 1 – Beginning	Mark
Understanding of Industry Problem	20%	Comprehensive understanding of real-world problem and	Good understanding with minor gaps in	Basic understanding; some requirements unclear	Poor understanding; misinterprets problem	

		constraints	requirements		context	
Application of Engineering Concepts	25%	Applies advanced and relevant concepts effectively to solve the problem	Applies appropriate concepts with minor errors	Limited application of concepts	Incorrect or no application of concepts	
Solution Design	25%	Innovative, practical, and feasible solution aligned with industry standards	Logical and feasible solution with minor gaps	Basic solution with limited feasibility	Unclear or impractical solution	
Use of Tools	15%	Effective use of modern tools, technologies, and real data	Appropriate use of tools with correct implementation	Limited or inconsistent use of tools	Minimal or incorrect use of tools	
Analysis	10%	Thorough analysis with validated results and performance evaluation	Good analysis with reasonable validation	Basic analysis with limited validation	Poor or no analysis	
Professionalism	5%	Highly professional, well documented, and clearly presented work	Good documentation and presentation	Basic documentation with some gaps	Poor documentation and presentation	

Q1. Analysis of Attack Extent and Lateral Movement

The organization has **150 interconnected systems**. During the investigation, attackers were found to exploit NULL sessions, exposed RPC services, and misconfigured shared folders. These vulnerabilities can allow attackers to enumerate systems and resources and perform lateral movement through SMB.

i. Initial Stage of Exploitation

It is given that **45% of the systems allow anonymous enumeration**.

Number of systems allowing anonymous enumeration:

$$150 \times 0.45 = 67.5 \approx 68 \text{ systems}$$

Among these systems, **60% are susceptible to SMB-based lateral movement**.

Therefore:

$$67.5 \times 0.60 = 40.5 \approx 41 \text{ systems}$$

Hence, approximately **41 systems are compromised during the initial stage**.

Percentage of the network initially compromised:

$$41/150 \times 100 \approx 27.3\%$$

Thus, more than one-fourth of the network may be affected in the initial stage.

ii. Second Stage: Lateral Movement

Each compromised system can attempt to access **3 additional systems**, with a success probability of **0.3** per attempt.

Expected successful compromises from one system:

$$3 \times 0.3 = 0.9$$

For approximately 41 compromised systems:

$$41 \times 3 \times 0.3 = 36.9 \approx 37 \text{ additional systems}$$

Therefore, the expected total number of compromised systems after two stages is:

$$41 + 37 = 78 \text{ systems}$$

Percentage of the total network:

$$78/150 \times 100 = 52\%$$

Therefore, approximately **52% of the network could be compromised after two stages**.

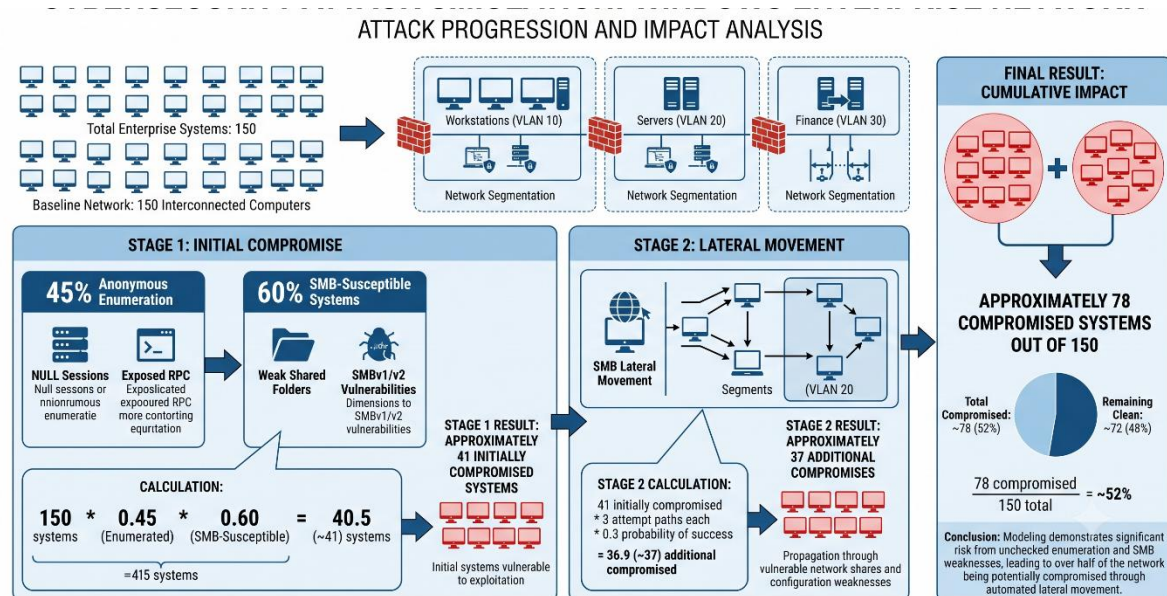


Figure 1: Estimated attack propagation through initial exploitation and SMB-based lateral movement.

iii. Risk of Large-Scale Compromise

A large-scale compromise is defined as affecting more than **70%** of the network.

$$150 \times 0.70 = 105 \text{ systems}$$

The estimated number compromised after two stages is **78 systems**, which is below the 105-system threshold.

Therefore, the attack **does not exceed 70% after two stages**. However, compromising approximately **52% of the network is still a serious security risk**. If lateral movement continues for additional stages, the number of affected systems could increase significantly.

iv. Vulnerability to Prioritize

NULL sessions should be prioritized for immediate mitigation because they can allow anonymous enumeration of users, systems, and shared resources. This information can help attackers identify targets for further attacks.

At the same time, **weak shared-folder/SMB configurations should be hardened immediately**, because SMB is directly involved in the lateral movement described in the scenario. Unnecessary RPC services should also be disabled or restricted to trusted systems.

The recommended priority is:

1. **Restrict NULL sessions and anonymous enumeration**
2. **Secure SMB and shared-folder permissions**
3. **Restrict unnecessary RPC exposure**

v. Conclusion

The analysis estimates that approximately **41 systems** may be compromised initially, followed by approximately **37 additional systems** through lateral movement. This gives an expected total of **78 compromised systems, or 52% of the network**, after two stages.

Although this is below the **70% large-scale compromise threshold**, it represents a significant security threat. Immediate mitigation of NULL sessions, weak SMB shares, and unnecessary RPC exposure, combined with network segmentation and least-privilege access, can significantly reduce the possibility of the attack spreading across the organization.

Q2. Analysis of RPC-Based Exploitation and Detection Risk

The enterprise network contains **120 systems**, of which **70 systems expose RPC services** to the internal network. Among these systems, **40% are vulnerable to known exploits**, and the probability of successful exploitation is **0.5**. Each exploitation attempt also has a **0.25 probability of generating a detection alert**.

i. Expected Number of Compromised Systems

Number of RPC-exposed systems:

70 systems

Vulnerable systems:

$70 \times 0.40 = 28$ systems

The probability of successful exploitation is 0.5. Therefore:

$28 \times 0.5 = 14$ systems

Hence, the expected number of successfully compromised systems is:

14 systems

ii. Expected Detection Alerts

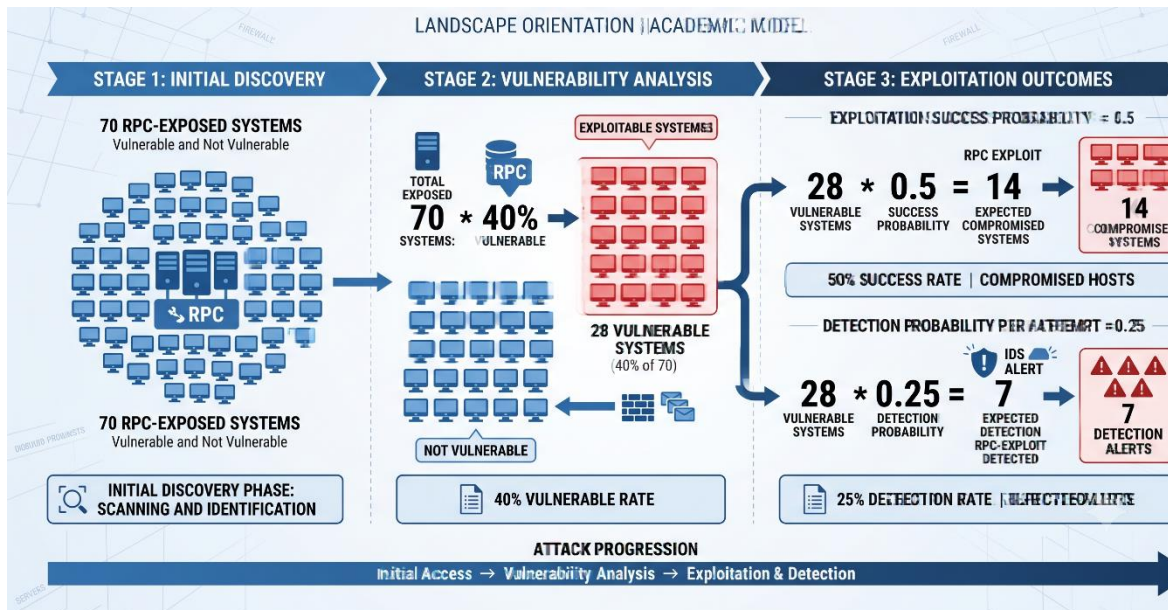
Each exploitation attempt has a detection probability of **0.25**.

Assuming an attempt is made against each of the 28 vulnerable systems:

$28 \times 0.25 = 7$ alerts

Therefore, the expected number of detection alerts is:

7 alerts



iii. Evaluation of Stealth Risk

An attacker attempting to remain stealthy would face a significant detection risk when exploiting the RPC vulnerabilities. Although the attacker could expect to compromise approximately **14 systems**, the exploitation process could generate around **7 detection alerts**.

This means the attacker has a reasonable chance of gaining access, but the activity is also likely to attract the attention of the organization's intrusion detection systems. Therefore, a stealth-focused attacker may avoid repeated direct exploitation and instead use alternative strategies such as credential-based access, exploiting already compromised systems, or other techniques that generate fewer detectable exploitation events.

From the defender's perspective, the results show that exposed and vulnerable RPC services represent a significant attack surface. Reducing unnecessary RPC exposure and improving monitoring can lower both the probability of successful compromise and the attacker's ability to remain undetected.

iv. Conclusion

Out of 70 RPC-exposed systems, approximately **28 are expected to be vulnerable**, resulting in an expected **14 successful compromises**. At the same time, approximately **7 detection alerts** may be generated. Therefore, direct RPC exploitation provides useful access to an attacker but carries a considerable detection risk, making alternative and more stealthy attack strategies attractive to a sophisticated attacker.

Q3. Analysis of Cloud Server Vulnerability and Full System Compromise

A cloud-hosted Linux server has four internet-facing critical services with independent vulnerability probabilities of **0.3, 0.2, 0.25, and 0.15**. The system also has weak file permissions that can be exploited with a probability of **0.5** after initial access.

i. Probability That at Least One Service Is Vulnerable

The probability that none of the four services is vulnerable is:

$$(1 - 0.3)(1 - 0.2)(1 - 0.25)(1 - 0.15)$$

$$= 0.7 \times 0.8 \times 0.75 \times 0.85$$

$$= 0.357$$

Therefore, the probability that at least one service is vulnerable is:

$$1 - 0.357 = 0.643$$

Hence, the probability that at least one service is vulnerable and exploitable is approximately:

$$64.3\%$$

ii. Probability of Full System Compromise

Once initial access is gained, weak file permissions can be exploited with a probability of **0.5**.

Therefore, the overall probability of full system compromise is:

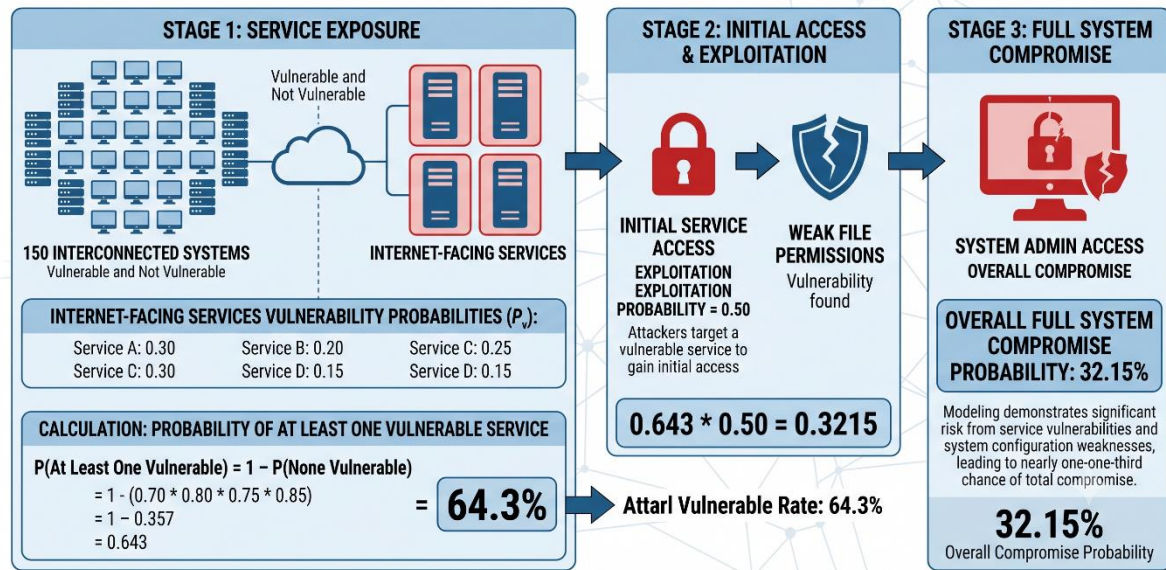
$$0.643 \times 0.5 = 0.3215$$

Thus:

$$\text{Full system compromise probability} = 32.15\%$$

This means there is approximately a **32.15% probability** of an attacker progressing from service exploitation to full system compromise through the weak file permissions.

ACADEMIC ATTACK PATH ANALYSIS: CLOUD-HOSTED LINUX SERVER



iii. Risk Evaluation

The results show that the server has a significant external attack surface. There is a **64.3% probability that at least one of the four exposed services is vulnerable**. Although the probability of progressing to full compromise is lower at **32.15%**, it is still a serious security risk for an internet-facing cloud server.

Strengthening file permissions alone would reduce the probability of privilege escalation after initial access, but it would **not eliminate the main entry-point risk**. Attackers could still exploit vulnerable internet-facing services and potentially perform other attacks after gaining initial access.

Therefore, file permissions should be strengthened, but security efforts should also focus on **patching vulnerable services, reducing unnecessary internet exposure, and implementing strong access controls and monitoring**.

iv. Conclusion

The probability that at least one service is vulnerable is **64.3%**, while the probability of full system compromise through weak file permissions is approximately **32.15%**. Strengthening file permissions is important, but doing so alone would not significantly eliminate the overall risk because the server still has multiple internet-facing vulnerable services. A layered security approach addressing both initial access and privilege escalation is therefore required.

Q4. Analysis of NFS Unauthorized Access and System Compromise

The organization uses NFS to share resources across three internal subnets. Due to improper configuration, the probabilities of unauthorized access from the three subnets are **0.4, 0.3, and 0.2**. Once access is obtained, the probability of privilege escalation to root access is **0.7**.

i. Probability of Unauthorized NFS Access

The probability that none of the three subnets gains unauthorized access is:

$$(1 - 0.4)(1 - 0.3)(1 - 0.2) \\ = 0.6 \times 0.7 \times 0.8 = 0.336$$

Therefore, the probability that at least one subnet successfully gains unauthorized access is:

$$1 - 0.336 = 0.664$$

Hence:

Probability of unauthorized NFS access = 66.4%

ii. Probability of Complete System Compromise

Once unauthorized NFS access is obtained, the probability of privilege escalation to root is **0.7**.

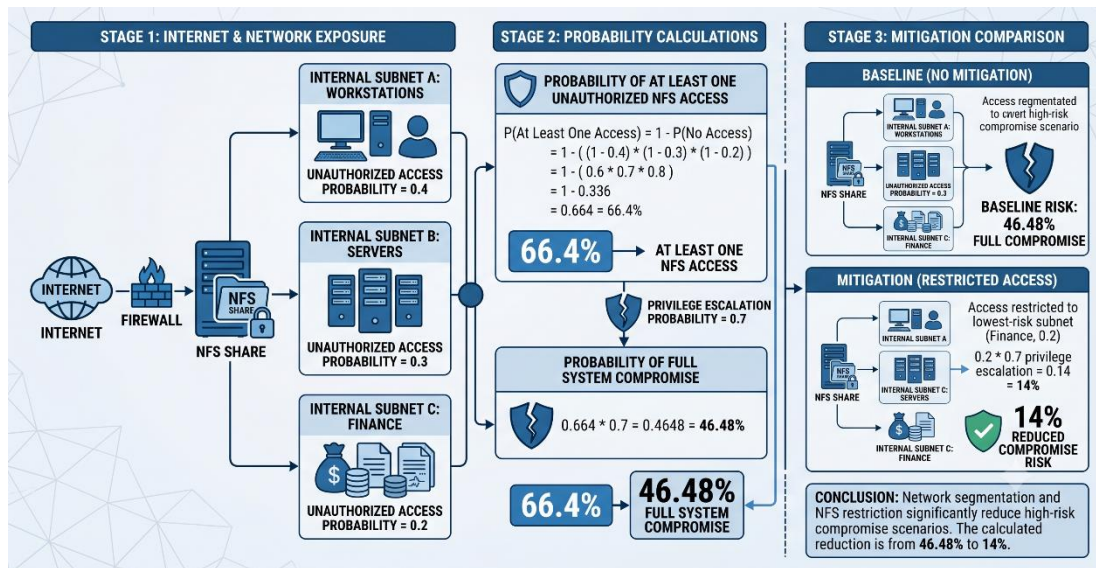
Therefore:

$$0.664 \times 0.7 = 0.4648$$

Thus, the overall probability of complete system compromise is:

$$46.48\% \approx 46.5\%$$

This indicates a significant risk because there is nearly a **one-in-two probability** of complete compromise under the given assumptions.



iii. Effectiveness of Restricting NFS to One Subnet

Restricting NFS access to a single subnet can significantly reduce the attack surface because it removes the unauthorized access opportunities from the other two subnets.

For example, if access is restricted to the subnet with the lowest unauthorized access probability (**0.2**), the probability of unauthorized access becomes **20%**.

The resulting probability of complete compromise would be:

$$0.2 \times 0.7 = 0.14 = 14\%$$

This is a major reduction from the original **46.48%** risk.

Therefore, restricting NFS access to a single trusted subnet is an **effective mitigation strategy**, especially when combined with proper NFS access controls, authentication, least-privilege permissions, and network segmentation.

iv. Conclusion

The probability that at least one subnet gains unauthorized NFS access is **66.4%**, while the overall probability of complete system compromise is approximately **46.5%**. Restricting NFS access to a single trusted subnet can substantially reduce this risk. If the subnet with a 0.2 unauthorized-access probability is selected, the estimated complete-compromise probability falls to **14%**.

Therefore, NFS access should be restricted to only the required trusted subnet, while strong authentication and access controls should also be implemented to provide additional protection.

Q5. Analysis of NFS Unauthorized Access and System Compromise

The organization uses NFS to share resources across three internal subnets. Due to improper configuration, the probabilities of unauthorized access from the three subnets are 0.4, 0.3, and 0.2. Once access is obtained, the probability of privilege escalation to root access is 0.7.

i. Probability of Unauthorized NFS Access

The probability that none of the three subnets gains unauthorized access is:

$$(1 - 0.4)(1 - 0.3)(1 - 0.2) \\ = 0.6 \times 0.7 \times 0.8 = 0.336$$

Therefore, the probability that at least one subnet successfully gains unauthorized access is:

$$1 - 0.336 = 0.664$$

Hence:

Probability of unauthorized NFS access = 66.4%

ii. Probability of Complete System Compromise

Once unauthorized NFS access is obtained, the probability of privilege escalation to root is 0.7.

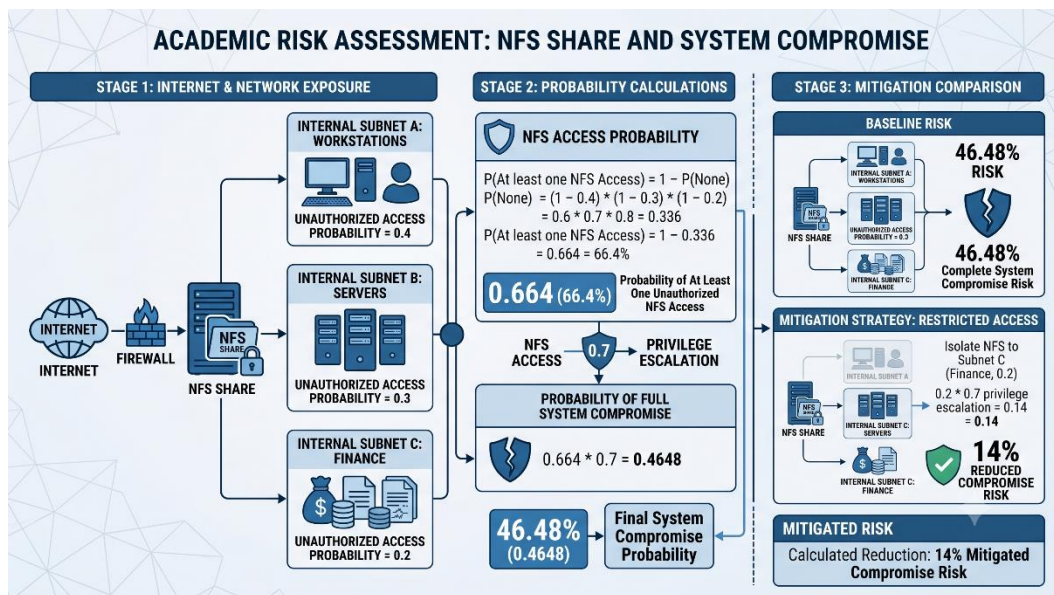
Therefore:

$$0.664 \times 0.7 = 0.4648$$

Thus, the overall probability of complete system compromise is:

$$46.48\% \approx 46.5\%$$

This indicates a significant risk because there is nearly a one-in-two probability of complete compromise under the given assumptions.



iii. Effectiveness of Restricting NFS to One Subnet

Restricting NFS access to a single subnet can significantly reduce the attack surface because it removes the unauthorized access opportunities from the other two subnets.

For example, if access is restricted to the subnet with the lowest unauthorized access probability (0.2), the probability of unauthorized access becomes 20%.

The resulting probability of complete compromise would be:

$$0.2 \times 0.7 = 0.14 = 14\%$$

This is a major reduction from the original 46.48% risk.

Therefore, restricting NFS access to a single trusted subnet is an effective mitigation strategy, especially when combined with proper NFS access controls, authentication, least-privilege permissions, and network segmentation.

iv. Conclusion

The probability that at least one subnet gains unauthorized NFS access is 66.4%, while the overall probability of complete system compromise is approximately 46.5%. Restricting NFS access to a single trusted subnet can substantially reduce this risk. If the subnet with a 0.2 unauthorized-access probability is selected, the estimated complete-compromise probability falls to 14%.

Therefore, NFS access should be restricted to only the required trusted subnet, while strong authentication and